

TOP 20 CONTROLS

Controls that matter

Version: 1.3

Author: Sylvain Martinez

Classification: PUBLIC

{**elysium**security}
cyber protection & response

This session focuses on the security controls that most organisations can realistically implement and sustain. It combines international best practice and hands on experience.

1. CONTEXT:

WHY SECURITY NEEDS CUSTOMISATION

2. CONTROL:

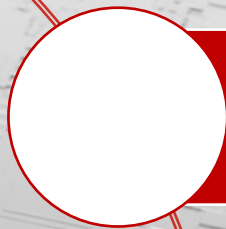
THE 20 CONTROLS THAT WORK

3. ROADMAP:

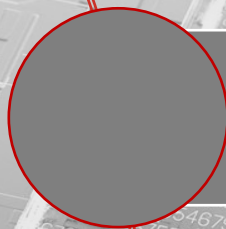
REALISTIC 30 DAYS TO 1 YEAR PLAN

4. TAKE AWAY:

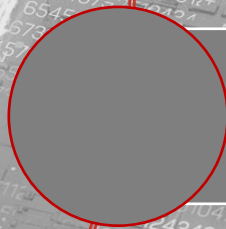
WHAT GOOD LOOKS LIKE



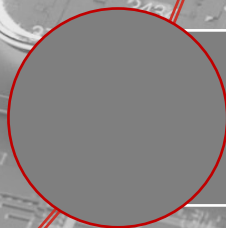
CONTEXT



CONTROLS



ROADMAP



TAKE AWAY

Cyber security often fails because organizations try to do too much with too little, instead of focusing on what matters most.



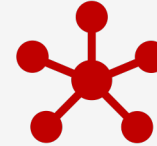
MATURITY

PEOPLE
TOOLING
PROCESSES



LIMITS

LIMITED BUDGET
LIMITED HEADCOUNT
LIMITED SPECIALISTS



DEPENDENCIES

CLOUD
PLATFORMS
3RD PARTIES



RESILIENCE

SINGLE INCIDENT
CAN BE
EXISTENTIAL

- Credential theft and MFA fatigue attacks.
- Business email compromise and invoice redirection.
- Ransomware through exposed services, unpatched endpoints or suppliers.
- Loss of availability from SaaS, endpoint, backup or identity compromise.

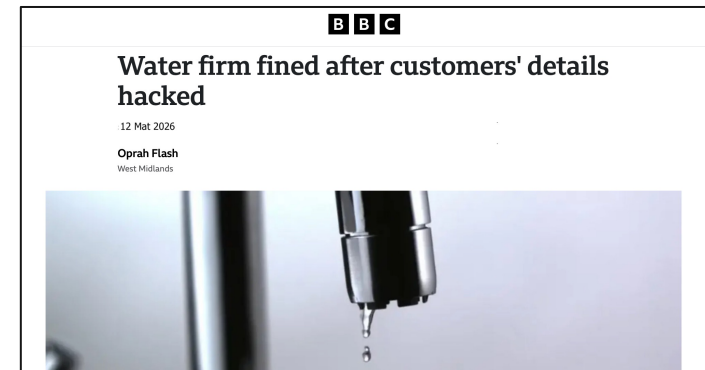


*Attacker is not always sophisticated
Operating Weakness is often the root cause*

- GDPR / MU DPA 2017: 72 hours notification
- BoM: Mandatory incident reporting to the central bank
- Clients' notification duty



USA – 2024 - ICE – \$10M



UK – 2026 - Water Company – £1M



DO NOT build your IR plan or Learn about your Legal requirements during an incident

- Reduce most likely attack path first
- Controls that are cheap to operate
- Simple to operate and manage
- Controls must be measurable

LIKELY**AFFORDABLE****OPERABLE****MEASURABLE**

*Not just technically correct
but also Operable month after month*

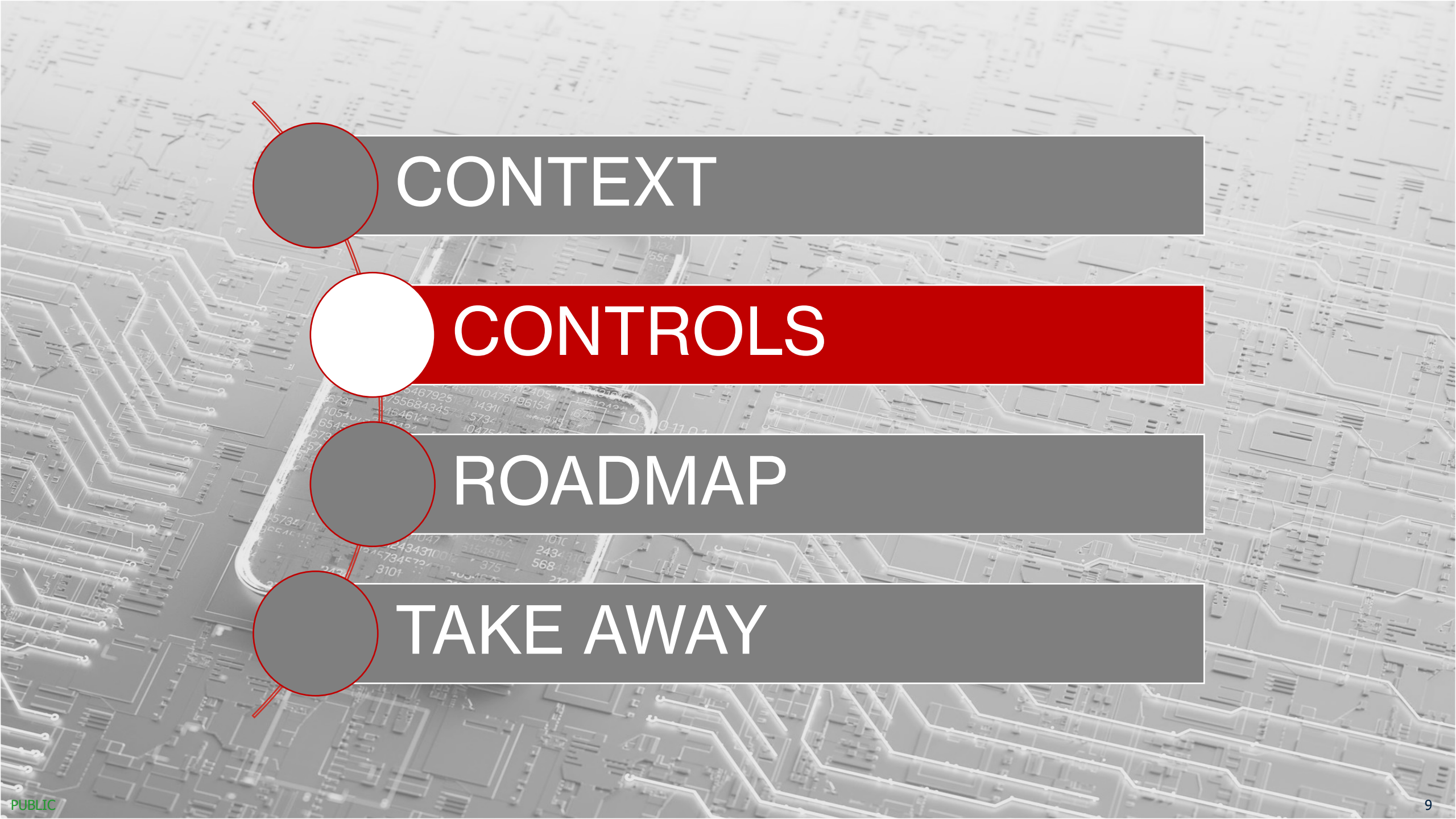
CIS IG1

NIST CSF 2.0

CISA / NCSC

- CIS IG1 gives a practical essential cyber hygiene baseline.
- NIST CSF 2.0 gives a risk management language across Govern, Identify, Protect, Detect, Respond and Recover.
- CISA and NCSC small business guidance keep the advice grounded in what smaller organisations can actually do.

*Use established Best Practices
Adapt them to your Risk Profile and Operational Model*



CONTEXT

CONTROLS

ROADMAP

TAKE AWAY

GOVERN

-  [1] Risk owner
-  [2] 3rd Party Security
-  [3] Asset inventory
-  [4] Critical data/processes

PROTECT

-  [5] MFA
-  [6] Least privilege
-  [7] Password Management
-  [8] Device Baseline
-  [9] Patching
-  [10] Endpoint Protection
-  [11] Email/Web Protection
-  [12] Awareness
-  [13] Backups
-  [14] Cloud/SaaS Baseline
-  [15] Network Baseline

IDENTIFY / DETECT

-  [16] Logging & Alerting
-  [17] External Exposure

RESPOND / RECOVER

-  [18] Incident Response
-  [19] Data Protection
-  [20] Measure & Improve

*Control set is intentionally **small enough to operate** and **broad enough to reduce** the main attack paths*

Costs are only indicative and to highlight not all controls have to be expensive to implement

**[GOVERN] CONTROL 1**

Name one accountable owner and put cyber risk on the management agenda.

- Assign an executive or Owner Responsible for Cyber Risk
- Keep a short risk register: top risks, owner, treatment, date.
- Review cyber risk quarterly, not only after incidents.

**[GOVERN] CONTROL 2**

Your providers are part of your attack surface. Do not ignore them

- List critical suppliers and what access/data they have.
- Check MFA, backup, incident notification and subcontractor practices.
- Make termination and access removal explicit in contracts.

**[GOVERN] CONTROL 3**

Know what you must protect before choosing tools.

- Maintain a list of users, devices, servers, SaaS platforms and critical suppliers.
- Mark business critical assets and unsupported systems.
- Review joiners, leavers and dormant accounts monthly.

**[GOVERN] CONTROL 4**

Identify what would hurt the business if lost, exposed or unavailable.

- Map cash collection, payroll, finance, customer data and operational systems.
- Classify sensitive personal, financial and contractual data.
- Define minimum recovery priority for each critical process

**[PROTECT] CONTROL 5**

Stop password compromise from becoming account takeover.

- Enable MFA on email, admin accounts, cloud platforms, VPN and finance systems.
- Prefer phishing-resistant MFA for administrators where possible.
- Disable legacy/basic authentication where it is still enabled.

[PROTECT] CONTROL 6

Reduce blast radius when a user or device is compromised.

- Separate daily user accounts from admin accounts.
- Remove local administrator rights from normal users.
- Review privileged accounts monthly and after staff changes.

**[PROTECT] CONTROL 7**

Make strong credentials usable, not aspirational.

- Use a business password manager for unique passwords.
- Store shared secrets in controlled vaults, not spreadsheets or chat.
- Rotate passwords after departures and supplier changes.

**[PROTECT] CONTROL 8**

Give every laptop and phone a minimum safe configuration.

- Require screen lock, encryption, supported OS and automatic updates.
- Block unmanaged devices from sensitive SaaS where feasible.
- Define a simple lost-device process.

[PROTECT] CONTROL 9

Close known holes before they become incidents.



- Enable automatic updates for OS, browsers and office applications.
- Patch internet-facing systems first.
- Track exceptions with owner and target date.

[PROTECT] CONTROL 10

Make commodity malware and ransomware harder to execute.

- Use reputable endpoint protection/EDR appropriate to size.
- Ensure tamper protection and cloud-delivered protection are enabled.
- Monitor devices that have gone stale or stopped reporting.

[PROTECT] CONTROL 11

Treat email as the main attack surface for most companies.



- Deploy SPF, DKIM and DMARC with monitored reporting.
- Use anti-phishing and safe-link/safe-attachment controls where available.
- Protect finance and invoice workflows with out-of-band verification.

[PROTECT] CONTROL 12

Train people on the decisions they actually make.

- Focus on phishing, payments, MFA prompts, data handling and incident reporting.
- Run short refreshers instead of annual theatre.
- Reward fast reporting; do not punish honest mistakes.

[PROTECT] CONTROL 13**Make ransomware survivable.**

- Keep offline or immutable backups for critical data.
- Test restore, not just backup completion.
- Protect backup admin accounts with MFA and separate credentials.

[PROTECT] CONTROL 14



Most companies' infrastructure is now rented, not owned. Yet, they need security

- Inventory SaaS applications and owners.
- Set secure defaults: MFA, admin alerts, external sharing limits and retention.
- Review integrations, OAuth apps and abandoned accounts.

[PROTECT] CONTROL 15

Do the simple network hygiene reliably.

- Change default router/firewall passwords.
- Use separate guest Wi-Fi and WPA3.
- Disable unused remote access and expose services only when needed.

**[IDENTIFY/DETECT]
CONTROL 16**



Detect the incidents you can realistically respond to.

- Alert on impossible travel, admin role changes, MFA resets and mailbox forwarding.
- Keep enough logs to reconstruct account and endpoint activity.
- Send alerts to a monitored mailbox or managed provider.

**[IDENTIFY/DETECT]
CONTROL 17**

See what attackers can reach from the internet.

- Scan domains and public IPs periodically.
- Track exposed RDP/VPN/admin portals and expired certificates.
- Fix critical external exposure before internal niceties.

**[RESPOND/RECOVER]
CONTROL 18**

Know who does what before the first hour is lost.



- Create a one-page incident response playbook.
- Prepare legal, insurance, IT provider, bank, regulator and communication contacts.
- Exercise one ransomware and one business email compromise scenario.

**[RESPOND/RECOVER]
CONTROL 19**

Reduce breach impact by keeping less sensitive data for less time.

- Know where personal and sensitive business data is stored.
- Apply least access and retention rules.
- Prepare breach assessment and notification workflow.

**[RESPOND/RECOVER]
CONTROL 20**

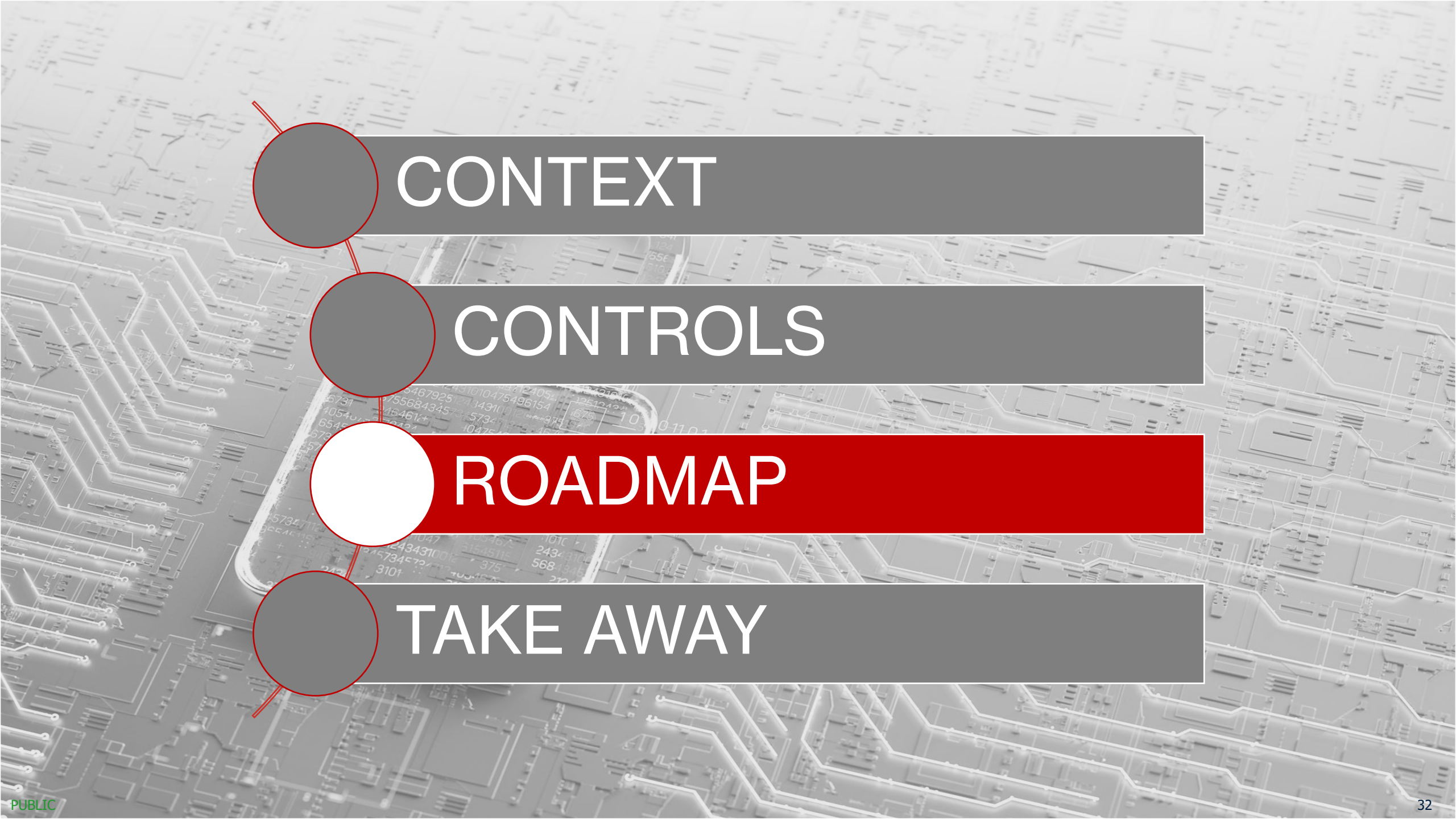


Make security a managed business process, not a project.

- Track a small set of indicators monthly.
- Review control exceptions and open risks.
- Use incidents and near misses to improve the baseline.

CONTROL 20 – In practice
You can only improve what you measure.
Five indicators, pulled monthly, that show whether the controls are actually holding

DOMAIN	INDICATOR	CTRL	GREEN — ON TRACK	RED FLAG
GOVERN	Overdue items on the risk register	[1]	0 past target date	Any open > 1 quarter
PROTECT	Admin accounts protected by MFA	[5]	100%	Below 100%
PROTECT	Critical patch latency, internet-facing systems	[9]	Patched within 14 days	Older than 30 days
IDENTIFY / DETECT	Open critical findings from external scan	[17]	0	Any open > 30 days
RESPOND / RECOVER	Last successful restore test of critical data	[13]	Passed within 90 days	Over 90 days / untested



CONTEXT

CONTROLS

ROADMAP

TAKE AWAY

The controls are not equal on day one.
Start with the controls that stop common compromise and preserve recovery.

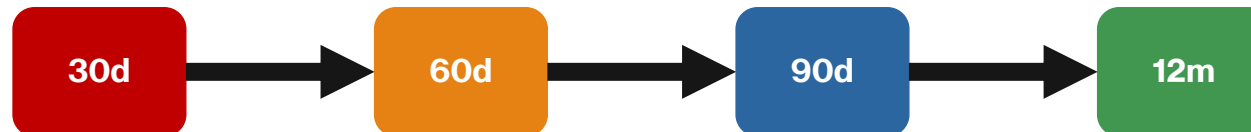
1. Stop account takeover

2. Preserve recovery

3. Reduce exposure

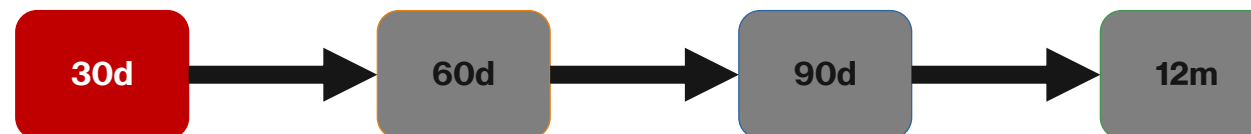
4. Manage the ecosystem

The roadmap assumes scarce time.
It prioritises controls that are visible, testable and immediately risk-reducing.



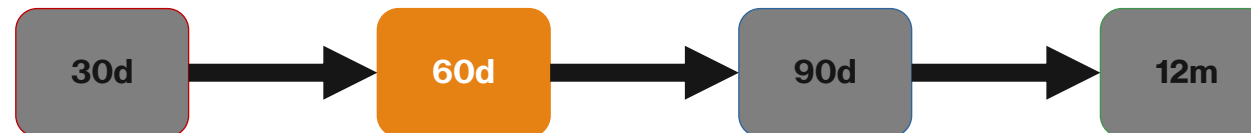
The roadmap assumes scarce time. It prioritises controls that are visible, testable and immediately risk-reducing.

- **[1]** Name the risk owner and create the risk register.
- **[5]** Enable MFA on email, admin, finance and cloud accounts.
- **[3]** Inventory users, devices, SaaS and critical suppliers.
- **[4, 13]** Confirm backups exist and run one restore test.
- **[18]** Create a one-page incident contact list.



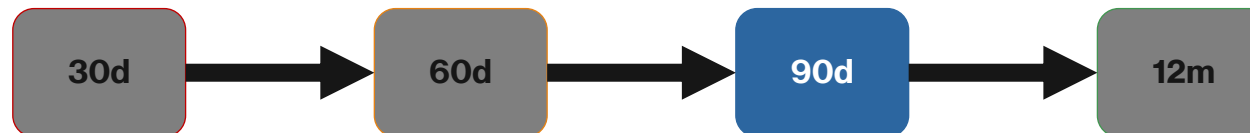
The roadmap assumes scarce time. It prioritises controls that are visible, testable and immediately risk-reducing.

- **[6, 7]** Remove unnecessary admin rights and dormant accounts.
- **[8, 9, 15]** Patch internet-facing systems, endpoints and browsers.
- **[8, 10]** Deploy or tune endpoint protection.
- **[4, 11]** Implement DMARC monitoring and payment verification rules.
- **[15, 17]** Create external exposure scan and remediation tracker.



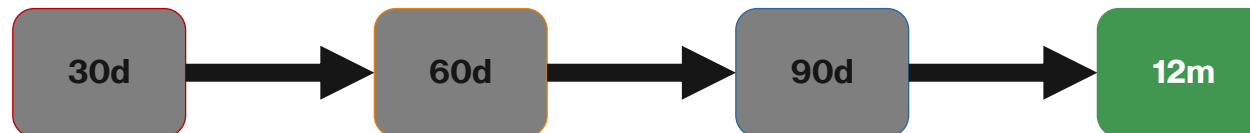
The roadmap assumes scarce time. It prioritises controls that are visible, testable and immediately risk-reducing.

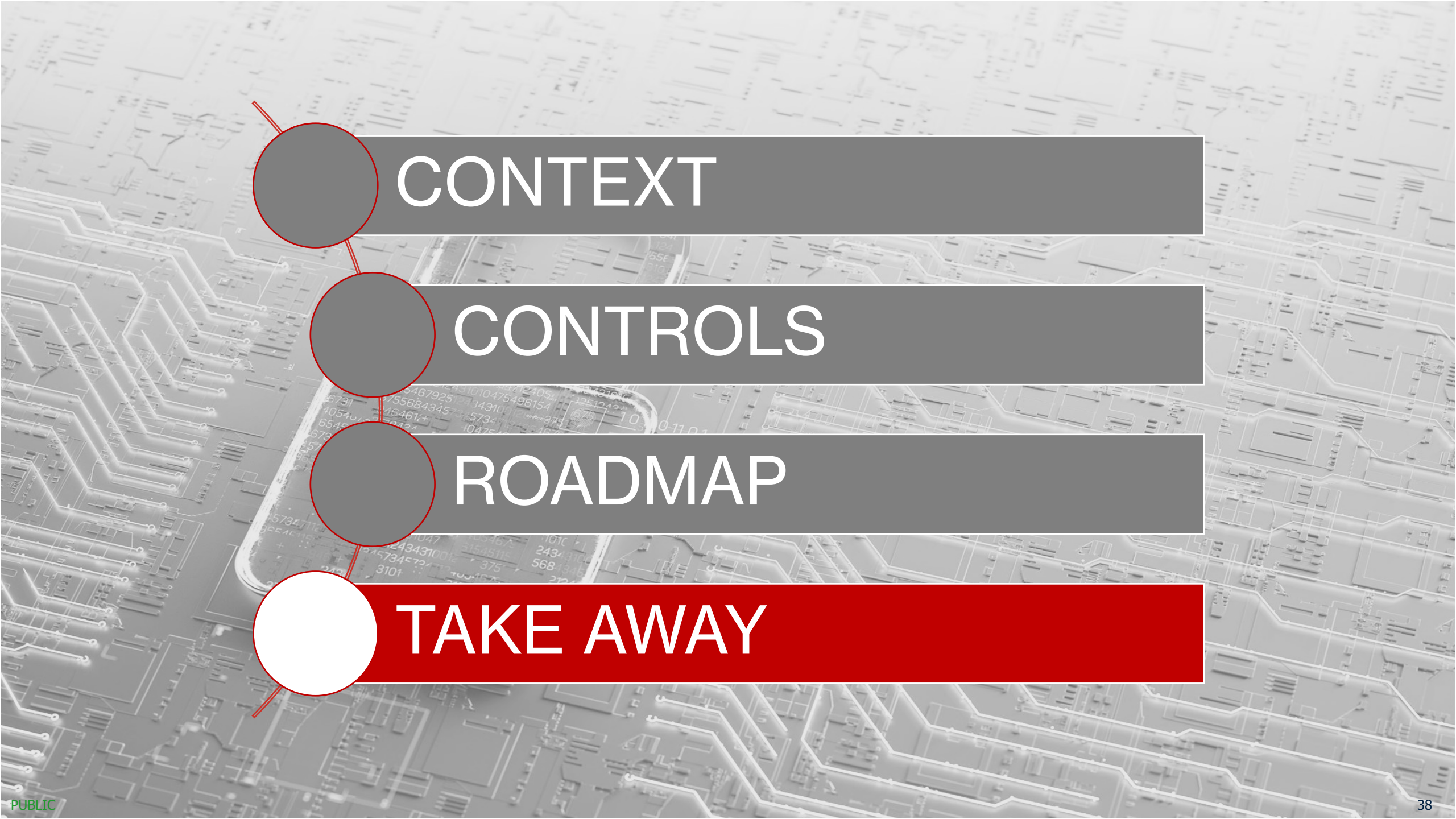
- **[8, 14]** Document secure device and SaaS baselines.
- **[16]** Configure priority identity/email/admin alerts.
- **[12]** Run one phishing/payment fraud awareness session.
- **[2]** Review supplier access and notification clauses.
- **[12, 18]** Run a ransomware or BEC tabletop exercise.



The roadmap assumes scarce time. It prioritises controls that are visible, testable and immediately risk-reducing.

- **[20]** Move from ad hoc actions to monthly control evidence.
- **[20]** Define 10 simple cyber KPIs for management review.
- **[13, 6]** Improve backup immutability and privileged access controls.
- **[4, 19]** Refine data retention and breach assessment workflow.
- **[20]** Decide whether managed security support is justified.





CONTEXT

CONTROLS

ROADMAP

TAKE AWAY

A realistic Security Operating model is small, disciplined and repeatable.

OWN

one accountable risk owner

CONTROL

20 pragmatic controls

TEST

restore and response exercises

REVIEW

monthly indicators and exceptions

**The objective is not perfect security.**

The objective is to:

- Make common compromise harder
- Recovery faster
- Business decisions better informed.

Use these as reference baseline, but translate them into controls the business can actually operate.

- CIS Controls Implementation Group 1 — essential cyber hygiene baseline.
- NIST Cybersecurity Framework 2.0 — Govern, Identify, Protect, Detect, Respond, Recover.
- CISA cyber guidance for small businesses and SMB resources.
- UK NCSC small organisations guide to cyber security.
- Mauritius Data Protection Act 2017 — personal data breach notification provisions.
- GDPR — supervisory notification where applicable.
- Bank of Mauritius Guideline on Cyber and Technology Risk Management — regulated financial institution lens.

THANK YOU!

Any Questions?



ABOUT ELYSIUMSECURITY LTD.

ELYSIUMSECURITY PROVIDES A PORTFOLIO OF **STRATEGIC** AND **TACTICAL SERVICES** TO HELP COMPANIES **PROTECT** AND **RESPOND** AGAINST **CYBER SECURITY THREATS**. WE DIFFERENTIATE OURSELVES BY OFFERING **DISCREET, TAILORED** AND **SPECIALIZED** ENGAGEMENTS.

ELYSIUMSECURITY OPERATES IN **MAURITIUS** AND IN **EUROPE**, A **BOUTIQUE STYLE** APPROACH MEANS WE CAN **EASILY ADAPT** TO YOUR BUSINESS OPERATIONAL MODEL AND REQUIREMENTS TO PROVIDE A **PERSONALIZED SERVICE** THAT FITS YOUR WORKING ENVIRONMENT.

ELYSIUMSECURITY PROVIDES **HIGH LEVEL EXPERTISE** GATHERED THROUGH YEARS OF **BEST PRACTICES EXPERIENCE** IN LARGE INTERNATIONAL COMPANIES ALLOWING US TO PROVIDE ADVICE BEST SUITED TO YOUR **BUSINESS OPERATIONAL MODEL** AND **PRIORITIES**.

ELYSIUMSECURITY PROVIDES **PRACTICAL EXPERTISE** TO **IDENTIFY VULNERABILITIES**, ASSESS THEIR **RISKS** AND **IMPACT**, **REMEDiate** THOSE RISKS, **PREPARE** AND **RESPOND** TO INCIDENTS AS WELL AS RAISE **SECURITY AWARENESS** THROUGH AN ORGANIZATION.

